

MSSP Platform Master Blueprint & Product Operations Manual

Document title: The MSSP Bible Product: Kestrel Cyber MSSP Control Plane Repository path: /opt/mssp-control
Control plane host: VM 100 — mssp-control (192.168.0.201) Document version: 1.0 As-of date: 2026-07-30
Classification: Internal engineering & operations — production reference

Source-of-truth hierarchy: live git commits/tags → validation-script PASS lines → inspected source files → this blueprint → older Knowledge Base prose.

Document control

Item	Value
Canonical Markdown	/opt/mssp-control/docs/MSSP_PLATFORM_MASTER_BLUEPRINT.md
PDF export	/opt/mssp-control/DOCS/MSSP_PLATFORM_MASTER_BLUEPRINT.pdf
DOCX export	/opt/mssp-control/DOCS/MSSP_PLATFORM_MASTER_BLUEPRINT.docx
Companion rulebooks	AGENTS.md, CLAUDE.md, CONTEXT.md, .cursor/rules/mssp-control-plane.mdc
Architecture roadmap	docs/KB036_MSSP_PLATFORM_ARCHITECTURE_ROADMAP.md
Containment honesty register	docs/KB091_ENTERPRISE_CONTAINMENT_HONESTY_GAPS.md

This document synthesizes Day-1 foundation through current operational state: multi-tenancy, co-managed RBAC, dual portals, Wazuh/Suricata/TheHive/Shuffle/Nuclei+Vuls adapters, EDR active response, connection pooling, and forensics streaming. Trivial typos, failed terminal noise, and superseded lab shortcuts are omitted. Architectural breakthroughs and root-cause fixes are retained in full.

1. Executive Summary & Business Architecture

1.1 Platform purpose

The MSSP Control Plane is a branded, multi-tenant Managed Security Service Provider / SOC / MDR / XDR product. It is not a re-skinned Wazuh dashboard, not a Streamlit prototype, and not a single-tenant tool.

The FastAPI backend on VM 100 is the system of record. Detection, scanning, case, and orchestration engines (Wazuh, Suricata, TheHive, Shuffle, Nuclei, Vuls, Greenbone CE) are backend adapters only. Customers and SOC staff interact with our Admin portal (:3000) and Customer portal (:3001). Third-party engine UIs are never the customer-facing product.

Production posture: On-prem local servers are the current production path for a complete end-to-end MSSP. The same architecture is intended to migrate to cloud when customer volume justifies it. Runtime defaults and dashboard copy must not use lab/demo wording. Tenant alert mapping is fail-closed (Wazuh group/binding required; no DEMO default). Shared TheHive org default: THEHIVE_DEFAULT_ORG=MSSP.

1.2 Tenantry & user model (co-managed governance)

Every customer organization is a row in tenants (id UUID, unique short_code). Tenant-scoped data always carries tenant_id.

Platform (MSSP) staff — Admin portal :3000

Role	Typical duties
platform_admin	Full platform administration, cross-tenant

Role	Typical duties
soc_manager	Cross-tenant SOC operations, triage ownership
soc_analyst	Cross-tenant triage; EDR write actions allowed (SOC_WRITE_ROLES)

Customer users — Customer portal :3001

Role	Typical duties
customer_admin	Tenant-scoped admin; may execute co-managed EDR actions (CUSTOMER_ACTION_ROLES)
customer_viewer	Read-only tenant views

Canonical roles are enforced by CHECK constraint on platform_users.role (postgres/init/002_kb010_auth_rbac.sql) and by FastAPI dependencies in backend-api/app/api/dependencies.py:

- get_current_user() — JWT (HS256, JWT_SECRET)
- require_roles(*allowed_roles)
- require_tenant_match() — customer wrong-tenant → HTTP 404 (not 403); MSSP roles exempt for cross-tenant work

Login is portal-separated: Admin accepts staff roles only; Customer accepts customer roles only (portal field on login). Customer UI never calls /admin APIs.

1.3 Target value proposition

Capability	Engine(s)	Control-plane outcome
SIEM / endpoint telemetry	Wazuh Manager + agents (VM 101)	Normalized security_alerts, process events, agent health
Network IDS	Suricata (VM 106) → Wazuh	Network alerts into same alert pipeline
Case / IR	TheHive (VM 102)	Cases synced; org/tag bound per tenant (KB-072)
SOAR	Shuffle (VM 102)	Playbooks, EDR workflow hop, forensics triggers
Vulnerability assessment	Nuclei + Vuls primary; Greenbone CE backup (VM 109)	vulnerabilities → Admin triage → customer-safe recommendations
Endpoint response (EDR/MXDR)	Wazuh Active Response + control-plane APIs	Isolate / unisolate / kill / block-hash / forensics with audit

Customer-facing copy never names third-party engines. Mapping lives in backend-api/app/services/customer_safe_labels.py (example: wazuh → “Endpoint monitoring”, nuclei/vuls/greenbone → “Vulnerability assessment”).

1.4 Evolution timeline (Day 1 → present)

Phase	KB / commit markers	Deliverable
Foundation	KB-001–KB-009A, tag kb008-validated-foundation	Compose stack, core schema, AI agent rules

Phase	KB / commit markers	Deliverable
Auth & APIs	KB-010–KB-017, tags kb010-auth-rbac-phase1-validated, kb011-protected-apis-validated	RBAC, protected APIs, tenants/users/appliances
Admin UI	KB-018–KB-020	Admin nginx portal foundation, activation tokens, prod/demo separation
Customer UI	KB-021–KB-035, tag kb035-customer-appliance-detail-validated (1ac1df3)	Full customer list/detail surface
Architecture docs	KB-036–KB-060	Enterprise roadmap, VM plan, ops runbooks
Live engines	KB-041–KB-049, KB-061–KB-063	Wazuh 4.14.6, Suricata, TheHive+Shuffle, ingress
Vuln & entitlements	KB-068–KB-079	Greenbone CE, Nuclei+Vuls, entitlements, contract onboard
EDR / MXDR	KB-083–KB-084 (af6175f ... 73376d6)	Actions, lifecycle, forensics stream, process trees
Portal & Windows	KB-088 (e13fc51)	User mgmt, portal auth, SPA fixes, Windows telemetry bar
Containment honesty	KB-091	Fail-closed OS resolve, Dispatched vs Verified, quarantine AR

2. High-Level Architecture & Infrastructure Topology

2.1 Network & control-plane topography

Live VMs (authoritative: [CONTEXT.md](#))

VM	Hostname	IP	Role	State
100	mssp-control	192.168.0.201	Control plane (this repository)	Production
101	wazuh-stack	192.168.0.211	Wazuh Manager / Indexer / Dashboard 4.14.6	Live
102	thehive_shuffle	192.168.0.212	TheHive + Shuffle	Live
106	suricata-sensor	192.168.0.216	Suricata IDS + Wazuh agent	Live
109	greenbone	192.168.0.219	Greenbone CE + Nuclei + Vuls (/opt/mssp-vuln-free)	Live
112	automation	192.168.0.222	Ansible controller	Ready
105	(former Linux lab)	—	Decommissioned 2026-07-29	Destroyed

Roadmap placeholders still documented in KB-036 (Zeek VM 107, MISP 108, Velociraptor 110, monitoring 111) remain future until an explicit KB installs them.

Exposed / referenced ports

Service	Address / port	Notes
Admin portal	192.168.0.201:3000	nginx → static SPA; /api/ → backend
Customer portal	192.168.0.201:3001	nginx → static SPA; /api/ → backend
Control-plane API	container :8000 (host \${API_PORT})	FastAPI
Wazuh API	https://192.168.0.211:55000	Active Response, agent queries
TheHive	http://192.168.0.212:9000	Case management
PostgreSQL / Redis	internal Docker network mssp-backend only	Not published to LAN by default

Docker Compose layout (/opt/mssp-control/docker-compose.yml)

Container	Image / build	Published
mssp-postgres	postgres:16-alpine	internal
mssp-redis	redis:7-alpine	internal (--requirepass)
mssp-backend-api	./backend-api	\${API_PORT}:8000
mssp-frontend-admin	./frontend-admin	3000:80
mssp-frontend-customer	./frontend-customer	3001:80

Network: bridge mssp-backend. Volumes: postgres_data, redis_data. Secrets mounted under /run/secrets/ (Wazuh API user/password, ingress tokens, Shuffle webhook, TheHive password, vuln sync key). Nginx configs use resolver 127.0.0.11 so upstream backend-api re-resolves after recreate (avoids customer login HTTP 502 from stale Docker DNS).

2.2 Core stack components & roles

1. Control plane API — backend-api/ (FastAPI, Python 3.12). App wiring: backend-api/app/main.py. Routes under backend-api/app/api/routes/. Business logic under backend-api/app/services/. Config/security: app/core/. DB pool: app/db/session.py. 2. SIEM / telemetry — Wazuh Manager on VM 101; Linux/Windows agents; Suricata events forwarded via Wazuh agent on VM 106. 3. Orchestration — Shuffle on VM 102; control-plane EDR also calls wazuh_client.run_active_response() and shuffle_edr_client.post_edr_workflow(). 4. Incident / case — TheHive on VM 102; control-plane incidents table remains SoR for portals; TheHive sync via KB-061 patterns. 5. Network & vulnerability — Suricata (106); Nuclei+Vuls primary and Greenbone CE backup (109). No scanners on VM 100. Greenbone Enterprise deferred (docs/KB077_GREENBONE_ENTERPRISE_READINESS_PLAN.md).

2.3 Data pipeline (endpoint → UI)

Endpoint event

- Wazuh Agent (Sysmon 1/3, Security 4688, Auditd, Suricata eve.json, ...)
- Wazuh Manager parse / rules (VM 101)
- Ingress / Sync paths into control plane
 - Instant Wazuh ingress (KB-063) / SOC sync
 - Shuffle hop → optional TheHive case
 - Vuln pullers (Nuclei/Vuls/Greenbone → vuln_sync)
- PostgreSQL normalize
 - security_alerts | incidents | edr_process_events | vulnerabilities | ...
- Dual APIs

```

/admin/* (SOC) | /customer/* (tenant-safe, labels stripped)
→ Portals
Admin :3000 process tree / triage / EDR actions
Customer :3001 plain-English summaries, co-managed actions where entitled

```

Normalization record shape (conceptual): tenant, source_platform, asset, alert, incident/case, recommendation, vulnerability, report, visibility_status, sync_health_status.

3. Core Database, API & RBAC Engineering

3.1 Schema overview

Base schema: postgres/init/001_mssp_core_schema.sql. Additive migrations 002–020 under postgres/init/.

Core tables

Table	Purpose
tenants	Customer orgs (short_code, status, SLA, criticality, timezone)
platform_users	All portal users (user_type, role, tenant_id, email unique)
tenant_contacts	Contact records
appliance_activation_tokens	One-time appliance activation
appliances	Collectors / appliances (appliance_uuid, health JSONB — customer-forbidden)
protected_assets	Monitored assets
appliance_heartbeats	Heartbeat history
security_alerts	Normalized alerts (raw_event JSONB — customer-forbidden; AI summary fields; customer_visible)
incidents	Cases (incident_number, internal_notes forbidden to customers)
incident_alerts, incident_timeline, incident_comments	Incident graph
notification_events	Notification history
customer_recommendations	Customer action items
monthly_reports	Published reports
audit_logs	Who/what/when (actor_user_id, actor_role from KB-085/016, source_ip, details JSONB)
vulnerabilities	KB-069+
tenant_entitlements	KB-071+
tenant_engine_bindings	KB-072 Wazuh group / TheHive org bindings
service_upgrade_requests	KB-076
edr_action_executions	KB-083/084 action ledger
edr_endpoint_isolation	Per (tenant_id, agent_id) isolation state
edr_telemetry_stats	Aggregate EDR counters

Table	Purpose
edr_forensic_artifacts	Upload metadata / object keys
edr_process_events	Process tree rows
tenant_asset_service_coverage	KB-086
tenant_agent_install_tokens	KB-086

EDR action model (edr_action_executions)

- action_type: ISOLATE_HOST | UNISOLATE_HOST | KILL_PROCESS | COLLECT_FORENSICS | BLOCK_HASH
- status: pending | executing | success | failed | verified | timeout (legacy executed normalized to success in API responses)
- Links: tenant_id, incident_id, alert_id, requested_by_user_id, target_agent_id, callback_payload, verified_at, external_ref

There is no table named users or devices in the production schema; use platform_users and protected_assets / agent IDs respectively.

3.2 Tenant isolation & API security

Rules (non-negotiable):

1. Every tenant-data query filters WHERE tenant_id = ... derived from the JWT, never from an unchecked client parameter. 2. Customer mismatch → 404. 3. Customer responses omit: password hashes, tokens, API keys, raw_event / raw_json / details / metrics / health_snapshot / report_file_path, IPs (source_ip, destination_ip, local_ip, ...), internal_notes, mitre_mapping (unless explicitly approved), stack traces. 4. Never commit or print .env. Secrets via Compose secrets / env only. 5. After backend-api recreate, recreate both frontends (nginx upstream DNS).

Major API surface mounts (backend-api/app/main.py)

Auth, health, admin, customer, tenant/user/appliance management, SOC sync, vuln sync, entitlements, EDR (/v1/edr), audit (admin + customer + v1), onboarding configs, agent packages, public agent install, delegated user management.

EDR HTTP API (backend-api/app/api/routes/edr.py, prefix /v1/edr)

Method	Path	Role
GET	/telemetry/process-tree	Authenticated, tenant-scoped
POST	/actions/execute	SOC write or customer_admin
POST	/actions/callback	X-EDR-Callback-Key / SOC sync key
GET	/actions/{execution_id}	Authenticated
PUT	/forensics/upload/{artifact_id}	HMAC token; streaming body
GET	/forensics/download/{artifact_id}	HMAC token
POST	/forensics/complete	Callback key
GET	/incidents/deep-dive	Authenticated
GET	/metrics/summary	Authenticated

3.3 Frontend applications

Portal	Path	Port	Router
Admin / SOC	frontend-admin/	3000	frontend-admin/src/App.tsx
Customer	frontend-customer/	3001	frontend-customer/src/App.tsx

Admin routes include dashboard, tenants, users, appliances, alerts, incidents, vulnerabilities, recommendations, notifications, reports, assets, audit (+ detail).

Customer routes include dashboard, alerts, incidents, assets, appliances detail, reports, recommendations, services, vulnerabilities, notifications, users, audit, account — no /admin.

Dashboard KPI tiles must link to destinations that match their labels (Events → /alerts, Collector health → /appliances, Open recommendations → /recommendations). The EDR / MXDR service metrics strip is a summary panel (MTTC, telemetry count, isolated endpoints), not a separate console; containment actions live on incident detail.

3.4 Database connection pooling

File: backend-api/app/db/session.py.

- Library: psycopg_pool.ConnectionPool (module singleton).
- Env: DB_POOL_MIN_SIZE (default 5), DB_POOL_MAX_SIZE (20), DB_POOL_TIMEOUT (30s), max_idle=300.
- Helpers preserved: fetch_all, fetch_one, execute, fetch_one_write, db_transaction.
- Row factory: psycopg.rows.dict_row.
- Redis helper colocated (REDIS_HOST / REDIS_PORT / REDIS_PASSWORD).

This replaced prior single-connection open/close patterns that exhausted connections under concurrent portal + sync + EDR load.

4. EDR Active Response & Endpoint Telemetry Engineering

4.1 OS-aware containment engine

Control plane service: backend-api/app/services/edr_actions.py.

Command resolution — _resolve_ar_command(base_command, win_command, agent_id):

1. Query agent OS via wazuh_client.get_agent_os(agent_id). 2. Unknown OS → fail closed (do not default to Linux). Historical bug: defaulting to Linux dispatched wrong AR binary on Windows. 3. Select Linux base command or Windows .cmd variant.

Env var	Default
EDR_WAZUH_ISOLATE_COMMAND	mssp-isolate-host
EDR_WAZUH_ISOLATE_COMMAND_WIN	mssp-isolate-host.cmd
EDR_WAZUH_KILL_COMMAND / _WIN	mssp-kill-process / .cmd
EDR_WAZUH_BLOCK_HASH_COMMAND / _WIN	mssp-block-hash / .cmd
EDR_ISOLATE_SECONDS	120 (auto-release hint)

Dispatch path: insert edr_action_executions → wazuh_client.run_active_response() → optional Shuffle workflow → audit log (portal, actor, agent, incident, source IP).

Honesty policy (KB-091): Manager acceptance of AR + “agent still active” is not proof of LAN quarantine. Agent must remain reachable to the Manager IP by design. UI/API prefer Dispatched until endpoint proves applied=true. Soft connectivity checks must not auto-promote to Verified.

4.2 Windows engineering

Source trees

- SoT scripts: `deploy/wazuh-active-response/windows/`
- Packaged zip: `deploy/wazuh-active-response/mssp-windows-edr-ar-remediate.zip`
- Synced copies for API image: `backend-api/app/endpoint_configs/windows-edr-ar/`
- Sync helper: `scripts/kb091_sync_windows_edr_ar_pack.sh`
- Installer: `Install-MsspWindowsEdrAr.ps1`
- Proof: `Test-MsspQuarantineProof.ps1`

Wrapper contract (.cmd)

Wazuh execd sends one JSON line on STDIN. Critical rules encoded in `mssp-isolate-host.cmd`:

- Do not use more (deadlocks under AR).
- Do not put JSON on cmd argv (quotes break).
- Launch PowerShell once; PowerShell reads STDIN, then invokes `.ps1`.

Host quarantine (mssp-isolate-host.ps1)

Industry meaning: network quarantine — default deny for IP traffic (TCP/UDP/ICMP), inbound and outbound, except a minimal allow-list:

- Wazuh Manager IP (default 192.168.0.211, overridable via `mssp-ar.env WAZUH_MANAGER_IP=`)
- Loopback
- DHCP client (UDP 67/68)

Implementation uses `netsh advfirewall`: set Domain/Private/Public Outbound=Block (and inbound hardening), disable broad RDP/SMB/WinRM allows, add explicit block rules (including SSH :22), drop existing sessions where possible. State persisted under `%ProgramData%\mssp-edr-isolate-state.json` and marker `mssp-edr-quarantine.active`.

Success log line operators must confirm:

QUARANTINE ACTIVE applied=true

Unisolate restores prior profile actions and removes MSSP rules.

ASCII-safe PowerShell (UTF-8 BOM) avoids PS 5.1 parse failures from Unicode em-dashes; `${name}` used instead of `$name`: drive-qualified variables.

Kill / block-hash

- `mssp-kill-process.ps1 / .py` — terminate target PID/process from AR JSON.
- `mssp-block-hash.ps1 / .py` — current implementation documents limited enforcement (text allow/deny list style); not full WDAC/AppLocker/ASR. Product must not market it as complete hash blocking until Wave 1 enforcement lands (KB-091 C3).

Telemetry prerequisites

Windows agent alone is not process-EDR ready. Required:

Source	Why
Sysmon Event ID 1 (Process Create)	Process tree / command lines

Source	Why
Sysmon Event ID 3 (Network)	Connection context
Windows Security 4688 with command-line auditing	Native process create fallback
Wazuh ossec.conf localfile channels	Ship Sysmon + Security logs to Manager

Bootstrap: `deploy/windows-endpoint-telemetry/Enable-MsspWindowsTelemetry.ps1`, `sysmon-windows-baseline.xml`, `scripts/bootstrap_windows_telemetry.ps1`. Templates also under `templates/endpoint-configs/` and `backend-api/app/endpoint_configs/`.

4.3 Linux engineering

Scripts (no extension) under `deploy/wazuh-active-response/`:

- `mssp-isolate-host` — `iptables/nft-style` quarantine with Manager `allow-list`
- `mssp-kill-process`
- `mssp-block-hash`

Process enrichment sources: Auditd, Osquery pack (`osquery-endpoint-pack.conf`), Wazuh agent parameters. Process tree builder prefers ProcessGuid lineage, then ParentProcessId (KB-084).

4.4 Asynchronous forensics pipeline

Service: `backend-api/app/services/edr_forensics_storage.py`.

1. `COLLECT_FORENSICS` creates `edr_forensic_artifacts` row (awaiting_upload). 2. Control plane issues HMAC-signed upload URL (`FORENSICS_SIGNING_SECRET` or `JWT_SECRET` fallback); TTL default 3600s. 3. Collector PUTs ZIP to `/v1/edr/forensics/upload/{artifact_id}?token=...`. 4. Handler consumes `request.stream()` via `write_upload_stream()` — chunked write to local disk (`EDR_FORENSICS_STORAGE_PATH`, default `/var/lib/mssp/forensics`) or S3 multipart (8 MiB parts when `EDR_S3_BUCKET` set). SHA-256 incremental; `max_bytes` abort deletes partials. No full-body RAM buffer (OOM prevention). 5. Optional forensics/complete attaches size/hash metadata. 6. UI issues short-TTL download URL (default 900s) — binaries not proxied through list APIs.

Object key pattern: `{tenant_id}/{endpoint_id}/{timestamp}_{artifact_id}.zip`.

4.5 Background state sweeper

`backend-api/app/services/edr_sweeper.py` — `asyncio` task at app startup:

- Interval: `EDR_SWEEP_INTERVAL` (default 60s)
- Stuck threshold: `EDR_STUCK_TIMEOUT` (default 120s)
- Action: `UPDATE edr_action_executions SET status='timeout' ... WHERE status='executing' AND updated_at < now() - interval`

Prevents permanent EXECUTING badges when AR callbacks never arrive.

5. Architectural Breakthroughs, Root Causes & Engineering Lessons Learned

5.1 Host isolation & Active Response

Symptom

Dashboard showed isolate success / verified, yet Windows hosts remained reachable (gateway ping, RDP, WinRM). Later, AR appeared “sent” but scripts never ran or hung.

Root causes (stacked)

1. False verification: Control plane treated “Manager accepted AR” + “agent still online” as isolation proof. Agent-online is expected when Manager IP is allow-listed. 2. Wrong OS command: `get_agent_os` defaulted to Linux → Windows agents received non-Windows AR names. 3. `.cmd` deadlock / `argv` corruption: Using more or placing JSON on the command line broke or hung `execd` → PowerShell never applied firewall rules. 4. Weak quarantine semantics: Early approaches over-focused on ICMP; real MDR quarantine requires profile default-deny plus lateral-protocol blocks. 5. PowerShell parse errors: Unicode em-dashes under Windows PowerShell 5.1 without BOM; `$name`: interpreted as drive-qualified variable. 6. Admin UI gap: Isolate controls existed on customer/incident side panels but were missing from full Admin incident detail in some builds.

Finalized solution

- OS-aware `_resolve_ar_command()` with unknown → fail closed.
- STDIN-only `.cmd` wrappers; hardened `.ps1` quarantine (netsh advfirewall, RDP/SMB/WinRM/SSH blocks, Manager/DHCP/loopback allow).
- Honesty labeling: Dispatched until endpoint log `QUARANTINE ACTIVE applied=true`; proof script `Test-MsspQuarantineProof.ps1`.
- Admin + Customer incident containment UI; enriched `audit_logs` (portal, actor role, agent, incident, source IP).
- Validators: `scripts/kb090_validate_windows_edr_ar_packaging.sh`, `kb091_validate_edr_containment_honesty.sh`, live E2E isolate → ports closed → unisolate → ports open.

Remaining gaps (documented, not hidden): AR → `/v1/edr/actions/callback` not yet posted by all scripts; block-hash lacks WDAC/AppLocker; shared callback key forgeability (KB-091 C5–C7). Do not market “isolation works end-to-end” without live proof on the target agent class.

5.2 Streaming uploads & OOM prevention

Problem

Large forensic ZIPs buffered in memory through API/SOAR webhook bodies risked worker OOM and request timeouts.

Solution

Presigned/HMAC direct upload; `write_upload_stream()` over `request.stream()`; optional S3 multipart; metadata-only callbacks. See §4.4 and `docs/KB084_EDR_LIFECYCLE_FORENSICS_PROCESS_TREES.md`.

5.3 Database connection optimization

Problem

Per-request raw connections under concurrent Admin UI, Customer UI, sync workers, and EDR callbacks caused pool starvation and latency spikes.

Solution

`psycpg_pool.ConnectionPool` singleton with explicit min/max/idle/timeout (§3.4). Call-site signatures unchanged to limit blast radius.

5.4 Background EDR sweeper

Problem

Actions left in executing when agents offline or AR silent → permanent spinner / false operator expectation.

Solution

edr_sweeper_loop() timeout transition to timeout with result message Action timed out (sweeper) (\$4.5).

5.5 Portal / nginx operational lesson

Recreating only backend-api left Admin/Customer nginx with stale upstream IPs → 502 on /api/auth/login.

Mitigations: recreate both frontends with the API; nginx resolver 127.0.0.11 for Docker DNS.

5.6 Dashboard KPI link integrity

Miswired tiles (e.g., “Events Collected” → appliances, “Automation / SLA” → tenants) trained operators incorrectly. Corrected mapping: events→alerts, collector health→appliances, recommendations→recommendations; EDR strip explained as metrics only.

6. Deployment, Operations & Verification Manual

6.1 Clean stack provisioning (VM 100)

Prerequisites: Docker + Compose plugin; project at /opt/mssp-control; populated .env (never commit); secrets files as referenced by Compose.

```
cd /opt/mssp-control
git branch --show-current
git status --short
docker compose pull # where applicable
docker compose up -d --build
docker compose ps
curl -fsS http://localhost:8000/health | jq .
curl -fsS -o /dev/null -w '%{http_code}\n' http://localhost:3000/
curl -fsS -o /dev/null -w '%{http_code}\n' http://localhost:3001/
```

Expected: health JSON with "api":"ok", "database":"ok", "redis":"ok"; portals return HTTP 200.

Apply pending SQL only via approved migration scripts (example EDR):

```
./scripts/kb083_apply_edr_migration.sh
./scripts/kb084_apply_edr_lifecycle_migration.sh
```

Do not delete/recreate postgres/init/ schema casually. Prefer additive migrations.

After any API change that recreates mssp-backend-api:

```
docker compose up -d --build backend-api frontend-admin frontend-customer
```

Smoke auth through both portals' /api/auth/login (expect 401 on bad password, never 502/405).

6.2 Customer onboarding & agent joining

High-level sequence (see also docs/KB075_CONTRACT_READY_CUSTOMER_ONBOARDING.md, docs/KB072_TENANT_ENGINE_PROVISIONING.md, docs/KB042_WAZUH_AGENT_ONBOARDING.md):

1. Create tenant in Admin (/tenants) with unique short_code, deployment mode (KB-073), entitlements (KB-071).
2. Provision engines — Wazuh agent group + TheHive org/tag bindings (tenant_engine_bindings).
3. Create customer_admin portal user; verify Customer :3001 login only.
4. Issue agent install token / package (KB-086 agent install tokens + Admin/Customer package APIs).
5. Enroll Wazuh agent against Manager 192.168.0.211; place agent in the tenant's group (fail-closed mapping).
6. Windows telemetry bootstrap — Sysmon baseline + 4688 command-line auditing + ossec.conf channels. Validate process tree populates before claiming EDR readiness.
7. Install Windows EDR AR pack from mssp-windows-edr-ar-remediate.zip / Install-MsspWindowsEdrAr.ps1; register AR commands on Manager (scripts/kb090_register_windows_edr_ar_commands.sh).
8. Verify alerts appear tenant-scoped; isolate rehearsal only on approved test hosts with proof script.

6.3 Day-2 maintenance

Health

```
docker compose ps
curl -fsS http://localhost:8000/health | jq .
./scripts/kb011_validate_protected_apis.sh
```

Feature-area validators (run what you changed):

Area	Script
Architecture docs	<code>./scripts/kb036_validate_mssp_platform_architecture_roadmap.sh</code>
Greenbone enterprise plan	<code>./scripts/kb077_validate_greenbone_enterprise_readiness_plan.sh</code>
Nuclei/Vuls	<code>./scripts/kb078_validate_nuclei_vuls_free_stack.sh</code>
EDR MXDR	<code>./scripts/kb083_validate_edr_mxdr.sh</code>
EDR lifecycle	<code>./scripts/kb084_validate_edr_lifecycle_gaps.sh</code>
Containment honesty	<code>./scripts/kb091_validate_edr_containment_honesty.sh</code>
Windows AR packaging	<code>./scripts/kb090_validate_windows_edr_ar_packaging.sh</code>

Database hygiene

- Prefer managed VACUUM via PostgreSQL autovacuum; for heavy tables (`security_alerts`, `audit_logs`, `edr_process_events`) schedule manual VACUUM (ANALYZE) during maintenance windows from inside `mssp-postgres`.
- Retain `audit_logs` per policy; archive before purge. Enrichment fields (`actor_role`, `portal`, `source IP`) are required for co-managed isolate accountability.
- Never truncate tenant tables without an approved purge playbook (`scripts/purge_lab_*.sh` are lab-oriented — use with extreme caution on production data).

Log rotation

- Docker JSON logs: configure daemon `log-opts max-size/max-file` on the host.
- Wazuh Manager / agent logs on VM 101 and endpoints: follow Wazuh rotation defaults; Active Response log `active-responses.log` is the quarantine proof channel.
- Forensics disk: monitor `EDR_FORENSICS_STORAGE_PATH`; expire `edr_forensic_artifacts` with `status=expired` per retention policy.

Backup posture

Follow `docs/KB060_BACKUP_MONITORING_UPGRADE_OPERATIONS_RUNBOOK.md` for PostgreSQL volume snapshots, Redis persistence expectations, and Proxmox VM snapshots of VM 100 before major upgrades. Prefer validation → commit → tag → snapshot (user-driven).

6.4 Safe change workflow

1. Inspect live files + git status (do not trust stale docs alone). 2. Plan; obtain approval for large architectural changes. 3. Implement minimal blast radius. 4. Run module validator + relevant regressions (kb011 when `auth/API/nginx` touched). 5. Smoke portals and the changed feature path. 6. Commit only when the human requests it; never commit `.env`.

7. Appendix

7.1 Key repository paths

Path	Role
/opt/mssp-control/docker-compose.yml	Runtime orchestration
/opt/mssp-control/backend-api/	FastAPI control plane
/opt/mssp-control/frontend-admin/	SOC portal
/opt/mssp-control/frontend-customer/	Customer portal
/opt/mssp-control/postgres/init/	Schema + migrations
/opt/mssp-control/deploy/wazuh-active-response/	AR SoT
/opt/mssp-control/scripts/	Validators & ops helpers
/opt/mssp-control/docs/	Knowledge Base corpus

7.2 Explicit deferred / future items

Zeek, MISP, Velociraptor, OpenCTI, Kubernetes, Greenbone Enterprise (KB-077), full AR callback Wave 1, and Windows kernel driver work remain paused or deferred unless an approved KB restarts them.

7.3 Document maintenance

Update this blueprint when: a new engine VM goes live; EDR semantics change; RBAC roles change; or a containment honesty gap is closed. Prefer editing the Markdown source, then regenerating PDF/DOCX via `scripts/export_mssp_master_blueprint.py`.

End of MSSP Platform Master Blueprint & Product Operations Manual.